

SAT FIXTURE - SYSTEM ACCEPTANCE

Application Security Review

hello-autotools @ e3ad863

OVERALL RATING

HIGH

PROCESS ASSURANCE

82%

NATIVE TIER

A

REPORT DATE

2026-09-27

top priority 8.5

28 of 42 processes OK, 11 gaps

ADR-0001 gate

SAT 20260927T141440Z

Sample data. Values are illustrative, shaped like a hello-autotools SAT run.

1 Executive summary

The review ran 42 processes across 6 families. 28 completed cleanly, 3 were skipped as not applicable with a probe receipt, and 11 left coverage gaps. Overall rating is **High**, driven by the highest verified priority score of 8.5. Process assurance is **82%**; a process that did not run is reported as a gap, never as a clean result.

CRITICAL	HIGH	MEDIUM	LOW	REFUTED
0	3	2	2	1

ID	FINDING	CVSS 4.0	PRIORITY	SEVERITY
AR-001	Stack buffer overflow: strcpy of CLI name into 32-byte buffer	8.5	8.5	HIGH
AR-003	OS command injection: name concatenated into system() command	8.5	7.2	HIGH
AR-002	Format string: CLI-derived message used as printf format	7.0	7.0	HIGH
AR-004	Out-of-bounds write: memcpy behind STORE_INT0 macro and template	7.3	6.2	MEDIUM
AR-005	Vendored cJSON 1.7.18 missing from SBOM; CVE match not performed	–	–	MEDIUM
AR-006	Runtime image runs as root; base image not pinned by digest	2.0	1.5	LOW
AR-007	Unchecked NULL from cJSON_PrintUnformatted used to build std::string	2.0	1.0	LOW
AR-008	Mismatched deallocation: free() on cJSON output (refuted)	4.8	0.0	REFUTED

2 Scope and process coverage

Every process in the flow appears here, including designed lanes that are not built yet. Credit c_i per process: **OK** = 1, **OK_WITH_GAPS** = measured coverage, **BLOCKED/FAILED/NOT_BUILT** = 0, **SKIPPED_NA** excluded from the denominator.

$$A = \frac{\sum_k w_k A_k}{\sum_k w_k} = \frac{1 \cdot 0.94 + 2 \cdot 1.00 + 3 \cdot 0.57 + 3 \cdot 1.00 + 4 \cdot 0.95 + 1 \cdot 0.00}{14} = 0.82$$

FAMILY	w_k	OK	GAPS	BLOCKED	NOT BUILT	N/A	A_k
Intake and discovery	1	4	1	0	0	0	0.94
Build resolution	2	4	0	0	0	0	1.00
Deterministic scan jobs	3	4	2	3	0	2	0.57
Native analysis substrate	3	5	0	0	0	0	1.00
LLM review lanes	4	11	1	0	0	1	0.95
Designed, not built	1	0	0	0	4	0	0.00

2.1 Intake and discovery

00-intake plus D01-D04 persona discovery.

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
00-intake	OK	1.00	intake.py E-001
02-repository-partition-discovery	OK	1.00	developer-engineer / D01 E-002
02-dev-project-discovery	OK	1.00	developer-engineer / D02
02-devops-project-discovery	OK	1.00	devops-engineer / D03
02-sre-operations-topology	OK_WITH_GAPS	0.70	sre-engineer / D04 No runbooks or monitoring config in target; topology inferred from Dockerfile only.

2.2 Build resolution

Build index, plan, resolution and hostile native build.

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
02-build-index	OK	1.00	build_index.py E-003
02-build-plan	OK	1.00	haiku / build planner
02-build-resolution	OK	1.00	repair loop, 1 retry
native-build	OK	1.00	audit-native (network none) E-004

2.3 Deterministic scan jobs

One graph node per evidence family, one attempt-bearing instance per tool (ADR-0010).

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
02-secrets-inventory	OK	1.00	gitleaks, key-material-file-inventory E-010
02-iac-config-scan	OK_WITH_GAPS	0.60	checkov, trivy-config, hadolint (tfsec, kube-linter BLOCKED: no image) tfsec and kube-linter declared but no pinned image; 2 of 5 scanner instances did not run. E-011

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
02-sbom-inventory	OK_WITH_GAPS	0.50	syft-directory syft found 0 components; vendored cJSON has no manifest. Second source (build index vendored members) not yet wired. E-012
02-sca-vulnerability-match	BLOCKED	0.00	grype Blocked on V16/V18 offline vulnerability DB mirror. No CVE matching was performed.
02-license-scan	OK	1.00	scancode-toolkit E-013
02-dependency-lifecycle	BLOCKED	0.00	dependency-lifecycle-transform EOL reference table unowned. Lifecycle of cJSON 1.7.18 reported unknown.
02-binary-hardening	BLOCKED	0.00	binskim M02 unresolved; no ELF hardening check ran on the built binary.
02-container-image-inventory	SKIPPED_NA	—	oci-archive-inventory applicability-probe: no OCI archive in inputs
02-mobile-sast	SKIPPED_NA	—	mobsfscan applicability-probe: no Android/iOS markers
02-source-sast	OK	1.00	semgrep (vendored packs), gosec/php* N/A E-014
ossf-scorecard	OK	1.00	scorecard (offline mode) E-015

2.4 Native analysis substrate

Compile DB, IR, CSA/CTU, CodeQL, correlation and deep confirmation.

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
compile-db + clang-tidy/ cppcheck	OK	1.00	audit-native E-020
llvm-ir + ir-facts + svf	OK	1.00	audit-native E-021
csa-ctu	OK	1.00	clang static analyzer + CTU E-022
codeql (security-extended + mythos-cpp)	OK	1.00	audit-codeql (breadth only, ADR-0006) E-023
correlation + deep- confirmation	OK	1.00	correlate, deep_confirm E-024

2.5 LLM review lanes

Hypothesis, refutation, verification, scoring and synthesis.

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
01-component-characterization	OK	1.00	component cloud

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
03-threat-model-dfd-stride	OK	1.00	DFD + STRIDE E-030
04-asvs-masvs	SKIPPED_NA	—	ASVS 5.0 no web/API surface; CLI only
05-native-memory	OK	1.00	IR + CSA + CodeQL review
06-cve-reachability	OK_WITH_GAPS	0.40	inventory + reachability No SCA matches to triage (02-sca BLOCKED); inventory from build index only.
13-fuzz-target-triage	OK	1.00	target ranking
15-deployment-hardening	OK	1.00	container/Dockerfile persona
07-red-team-adversarial	OK	1.00	general + known-list + kill-chain
08-blue-team-refutation	OK	1.00	refutation
09-independent-verification	OK	1.00	evidence-only verifier E-040
11-remediation-proposal	OK	1.00	patch + retest in audit-native
12-scoring-prioritization	OK	1.00	CVSS 4.0 + EPSS/KEV
10-synthesis-report	OK	1.00	this document

2.6 Designed, not built

Design-v3 lanes with no evidence-gathering step yet. Counted as gaps.

PROCESS	STATUS	c_i	TOOLS / GAP / RECEIPT
L6B threat-model reconciliation	NOT_BUILT	0.00	Designed in design-v3, no lane.
L10 protocol/parser analysis	NOT_BUILT	0.00	Designed in design-v3, no lane.
L12 supply-chain / provenance	NOT_BUILT	0.00	Tier B scripts exist, not wired.
L13 privacy / data protection	NOT_BUILT	0.00	Designed in design-v3, no lane.

3 Findings

Findings reach this section only after refutation (lane 08) and, for High or Critical, independent verification (lane 09). Refuted hypotheses are kept for the record with priority zero.

AR-001

HIGH

Stack buffer overflow: strcpy of CLI name into 32-byte buffer

LOCATION src/greet.cpp:18

COMPONENT cli/greeting CWE-121, CWE-676

CVSS 4.0 CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
8.5 High

EVIDENCE / STATUS DIRECT_EVIDENCE · VERIFIED · reachable-default

$$P = \min(10, 8.5 \times 1.00 \times 1.00 \times 1.00 \times 1.00) = 8.5$$

The greeting "Hello, " + name + "!" is copied into char buf[32] with strcpy. A name of 24 or more characters overflows buf. Reached on every run. A hardened distro build aborts via `_FORTIFY_SOURCE`; an unhardened or ASan build shows the corruption.

```
src/greet.cpp lines 13-20
13 // This is intentional: it is the seeded defect this fixture target
14 // exists to exercise for source/native SAST and dynamic tools. See
15 // docs/VULNERABILITIES.md for details and the expected finding.
16 std::string build_greeting(const std::string &name) {
17     char buf[32];
18     std::strcpy(buf, ("Hello, " + name + "!").c_str());
19     return std::string(buf);
20 }
```

build_greeting(): buf is 32 bytes; strcpy has no bound.

LANE TRAIL

tool semgrep insecure-use-strcpy, CSA, CodeQL → **07** hypothesis RT-001 → **08** refutation failed: no length check on any path → **09** VERIFIED: ASan stack-buffer-overflow at greet.cpp:18 → **11** patch: bounded copy, retest OK → **12** scored

EVIDENCE

E-014 **semgrep**: 02-source-sast/semgrep/outputs/results.sarif (greet.cpp:18, logger.cpp:16, runner.cpp:18, jsonreport.cpp:19)

E-022 **csa-ctu**: native/csa/*.plist (greet.cpp:18, jsonreport.cpp:17)

E-023 **codeql**: codeql/security-extended.sarif + mythos-cpp.sarif

E-040 **09-independent-verification**: outputs/09/verification.json (ASan logs attached)

REMEDIATION

Return the std::string directly, or use a bounded copy and reject oversize names.

AR-003

HIGH

OS command injection: name concatenated into system() command

LOCATION src/runner.cpp:17-18

COMPONENT reporting CWE-78

CVSS 4.0 CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
8.5 High

EVIDENCE / STATUS DIRECT_EVIDENCE · VERIFIED · reachable-flag

$$P = \min(10, 8.5 \times 1.00 \times 1.00 \times 0.85 \times 1.00) = 7.2$$

With --report, the CLI name is spliced into an echo command and passed to system(). A double quote breaks out of the quoted argument and runs arbitrary shell commands with the process's privileges.

```
src/runner.cpp lines 12-19
12 // the privileges of this process. There is no shell-metacharacter
13 // escaping or use of a safer exec* family call with an argv array.
14 //
15 // Intentional seeded defect -- see docs/VULNERABILITIES.md.
16 void run_report(const std::string &name) {
17     std::string cmd = "echo \"report for " + name + "\" >>
18     /tmp/hello-autotools.log";
19     std::system(cmd.c_str());
20 }
```

run_report(): no escaping; system(3) runs the string through /bin/sh.

```
src/main.cpp lines 57-66
57         std::cout << "stored " << name.size() << " byte(s) into a "
58                 << sizeof(slot) << "-byte slot" << std::endl;
59     }
60
61     if (report) {
62         run_report(name);
63     }
64
65     return 0;
66 }
```

Only call site, behind --report.

LANE TRAIL

tool semgrep, CodeQL cpp/command-line-injection → **05** data flow argv -> name -> cmd confirmed in IR
→ **07** hypothesis RT-003 → **08** not refuted; flag gate lowers reachability only → **09** VERIFIED: --report
'x';touch /tmp/pwned;echo "" creates the file → **12** scored

EVIDENCE

E-014 **semgrep**: 02-source-sast/semgrep/outputs/results.sarif (greet.cpp:18, logger.cpp:16, runner.cpp:18, jsonreport.cpp:19)

E-021 **ir-facts / component IR slice**: native/ir-slices/*.json (memcpy@store.h:30 N=16; system@runner.cpp:18)

E-023 **codeql**: codeql/security-extended.sarif + mythos-cpp.sarif

E-040 **09-independent-verification**: outputs/09/verification.json (ASan logs attached)

REMEDIATION

Write the log line with file I/O instead of a shell, or use execve with an argv array.

AR-002

HIGH

Format string: CLI-derived message used as printf format

LOCATION src/logger.cpp:16

COMPONENT cli/logging CWE-134

CVSS 4.0 CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:P/VC:H/VI:L/VA:H/SC:N/SI:N/SA:N
7.0 High

EVIDENCE / STATUS DIRECT_EVIDENCE · VERIFIED · reachable-default

$$P = \min(10, 7.0 \times 1.00 \times 1.00 \times 1.00 \times 1.00) = 7.0$$

log_message() passes the greeting, which embeds the CLI name, straight to printf as the format. Conversion specifiers in the name are interpreted.

```
src/logger.cpp lines 11-18
11 // (e.g. "%x %x %x") or crash the process (e.g. "%s" reading an
12 // invalid pointer). The fix is 'std::printf("%s\n", message.c_str())`.
13 //
14 // Intentional seeded defect -- see docs/VULNERABILITIES.md.
15 void log_message(const std::string &message) {
16     std::printf(message.c_str());
17     std::printf("\n");
18 }
```

log_message(): message is the format argument.

LANE TRAIL

tool semgrep printf-format, CodeQL cpp/tainted-format-string → **07** hypothesis RT-002 → **08** not refuted
→ **09** VERIFIED: '%x %x %x %x' leaks stack words → **12** scored

EVIDENCE

E-014 **semgrep**: 02-source-sast/semgrep/outputs/results.sarif (greet.cpp:18, logger.cpp:16, runner.cpp:18, jsonreport.cpp:19)

E-023 **codeql**: codeql/security-extended.sarif + mythos-cpp.sarif

E-040 09-independent-verification: outputs/09/verification.json (ASan logs attached)

REMEDIATION

`std::printf("%s\n", message.c_str());`

AR-004

MEDIUM

Out-of-bounds write: memcpy behind STORE_INT0 macro and template

LOCATION src/store.h:30 (via src/main.cpp:56)
COMPONENT storage CWE-787, CWE-120
CVSS 4.0 CVSS:4.0/AV:L/AC:L/AT:P/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
7.3 High
EVIDENCE / STATUS DIRECT_EVIDENCE · VERIFIED · reachable-flag

$$P = \min(10, 7.3 \times 1.00 \times 1.00 \times 0.85 \times 1.00) = 6.2$$

STORE_INT0 expands to `copy_into_fixed<16>`, which memcpys the whole name into a 16-byte stack slot. Only the tools that see through macro expansion and template instantiation report it; this is the fixture's control for that capability.

```
src/store.h lines 25-35
25 // this isn't behind glibc's _FORTIFY_SOURCE strcpy checking by
26 // name -- but memcpy with a compile-time-known destination size is
27 // still eligible for __memcpy_chk fortification on a hardened
28 // toolchain, so the same "aborts instead of silently corrupting"
29 // caveat from VULN-01 can apply here too. See docs/VULNERABILITIES.md.
30 std::memcpy(dst, src.data(), src.size());
31 }
32
33 // The macro layer: call sites use STORE_INT0(...), not
34 // copy_into_fixed(...) directly, so reaching the vulnerable memcpy
35 // requires seeing through both this macro expansion and the template
```

`copy_into_fixed<N>()`: copies `src.size()` bytes into `N`-byte `dst`.

```
src/main.cpp lines 51-61
51 std::cout << build_json_report(name, greeting) << std::endl;
52 }
53
54 if (store) {
55     char slot[16];
56     STORE_INT0(slot, name);
57     std::cout << "stored " << name.size() << " byte(s) into a "
58               << sizeof(slot) << "-byte slot" << std::endl;
59 }
60
61 if (report) {
```

Instantiated as `copy_into_fixed<16>` through the macro, behind `--store`.

LANE TRAIL

tool stock CodeQL: 0 hits; mythos-cpp: 1 hit; semgrep: 0 hits → 05 IR slice: `memcpy size = name.size(), dst = 16` → 07 hypothesis RT-004 → 08 refutation failed: no clamp before copy → 09 VERIFIED_PRIMITIVE → 12 scored

EVIDENCE

E-021 ir-facts / component IR slice: native/ir-slices/*.json (memcpy@store.h:30 N=16; system@runner.cpp:18)
E-023 codeql: codeql/security-extended.sarif + mythos-cpp.sarif
E-024 deep-confirmation: deep-confirmation.json cluster C-007
E-040 09-independent-verification: outputs/09/verification.json (ASan logs attached)

REMEDIATION

Check `src.size() < N` before the copy, or truncate explicitly.

AR-005

MEDIUM

Vendored cJSON 1.7.18 missing from SBOM; CVE match not performed

LOCATION vendor/cJSON-1.7.18/
COMPONENT supply chain CWE-1104
CVSS 4.0 not scored
EVIDENCE / STATUS DIRECT_EVIDENCE · UNRESOLVED · unknown

$P = \text{unscored (coverage finding; reviewer severity: Medium)}$

The build links a vendored cJSON that no manifest declares, so the SBOM omits it and no vulnerability match ran. The fixture documents CVE-2025-57052 for this version; this review cannot confirm or clear it until SCA runs. Lane 06 found no call to the JSON-pointer API in project code.

LANE TRAIL

tool syft: 0 components; build index: vendored member → **06** inventory mismatch flagged; affected-API use not found in src/ → **09** UNRESOLVED: 02-sca-vulnerability-match BLOCKED

EVIDENCE

E-003 02-build-index: data/jobs/02-build-index/build-index.json#vendored[0]
 E-012 syft-directory: 02-sbom-inventory/syft-directory/outputs/sbom.cdx.json (0 components)
 E-013 scancode-toolkit: 02-license-scan/outputs/scancode.json#vendor/cJSON-1.7.18 (MIT)

REMEDIATION

Feed build-index vendored members into the SBOM and unblock 02-sca-vulnerability-match (V16/V18).

AR-006

LOW

Runtime image runs as root; base image not pinned by digest

LOCATION Dockerfile:4, Dockerfile:21-23
COMPONENT deployment CWE-250
CVSS 4.0 CVSS:4.0/AV:L/AC:H/AT:P/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N
2.0 Low
EVIDENCE / STATUS DIRECT_EVIDENCE · VERIFIED · reachable-build-config

$P = \min(10, 2.0 \times 1.00 \times 1.00 \times 0.75 \times 1.00) = 1.5$

Both stages use debian:bookworm-slim by tag, and the runtime stage has no USER instruction, so the binary runs as root. Three scanners agree.

Dockerfile	lines 16-23
16 RUN autoreconf -fi \	
17 && ./configure \	
18 && make \	
19 && make check	
20	
21 FROM debian:bookworm-slim	
22 COPY --from=build /src/hello-autotools /usr/local/bin/hello-autotools	
23 ENTRYPOINT ["/usr/local/bin/hello-autotools"]	

Final stage: floating tag, no USER before ENTRYPOINT.

LANE TRAIL

tool hadolint DL3006/DL3002, checkov CKV_DOCKER_3, trivy DS002 → **15** container baseline → **09** VERIFIED → **12** scored

EVIDENCE

E-011 hadolint, checkov, trivy-config: 02-iac-config-scan/tool-results.json

REMEDIATION

Pin FROM by digest and add a non-root USER before ENTRYPOINT.

AR-007

LOW

Unchecked NULL from cJSON_PrintUnformatted used to build std::string

LOCATION	src/jsonreport.cpp:16-17
COMPONENT	reporting/json CWE-476
CVSS 4.0	CVSS:4.0/AV:L/AC:H/AT:P/PR:N/UI:P/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N 2.0 Low
EVIDENCE / STATUS	STRONG_INFERENCE · UNRESOLVED · reachable-flag

$$P = \min(10, 2.0 \times 0.80 \times 0.70 \times 0.85 \times 1.00) = 1.0$$

cJSON_PrintUnformatted returns NULL when allocation fails, and std::string(nullptr) is undefined behavior. Only reachable with --json under memory pressure.

```
src/jsonreport.cpp lines 12-22
12  cJSON *root = cJSON_CreateObject();
13  cJSON_AddStringToObject(root, "name", name.c_str());
14  cJSON_AddStringToObject(root, "greeting", greeting.c_str());
15
16  char *rendered = cJSON_PrintUnformatted(root);
17  std::string result(rendered);
18
19  free(rendered); // cJSON allocates with malloc(); must be freed with free(), not
    delete.
20  cJSON_Delete(root);
21
22  return result;
```

rendered can be NULL on allocation failure.

LANE TRAIL

tool CSA core.NonNullParamChecker → 07 hypothesis RT-007 → 08 partial: only under allocation failure
→ 09 UNRESOLVED: not reproducible without fault injection → 12 scored

EVIDENCE

E-022 csa-ctu: native/csa/*.plist (greet.cpp:18, jsonreport.cpp:17)

REMEDIATION

Check rendered for NULL before constructing the string.

AR-008

REFUTED

Mismatched deallocation: free() on cJSON output (refuted)

LOCATION	src/jsonreport.cpp:19
COMPONENT	reporting/json CWE-762
CVSS 4.0	CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:P/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N 4.8 Medium
EVIDENCE / STATUS	WEAK_INFERENCE · REFUTED · reachable-flag

$$P = \min(10, 4.8 \times 0.50 \times 0.00 \times 0.85 \times 1.00) = 0.0$$

The scanner assumed a C++ allocation. cJSON allocates with malloc by default and the project never installs custom hooks, so free() is correct.

```
src/jsonreport.cpp lines 14-23
14     cJSON_AddStringToObject(root, "greeting", greeting.c_str());
15
16     char *rendered = cJSON_PrintUnformatted(root);
17     std::string result(rendered);
18
19     free(rendered); // cJSON allocates with malloc(); must be freed with free(), not
    delete.
20     cJSON_Delete(root);
21
22     return result;
23 }
```

Flagged line; refuted.

LANE TRAIL

tool semgrep c.lang.memory mismatched free → **07** hypothesis RT-008 → **08** REFUTED: cJSON default hooks allocate with malloc; no cJSON_InitHooks call in project → **09** concurs

EVIDENCE

E-014 **semgrep**: 02-source-sast/semgrep/outputs/results.sarif (greet.cpp:18, logger.cpp:16, runner.cpp:18, jsonreport.cpp:19)

REMEDIATION

None required.

4 Coverage gaps

Each item below is an area the review did not fully examine. None of them may be read as “no issues”.

- 02-sre-operations-topology **OK_WITH_GAPS** — No runbooks or monitoring config in target; topology inferred from Dockerfile only.
- 02-iac-config-scan **OK_WITH_GAPS** — tfsec and kube-linter declared but no pinned image; 2 of 5 scanner instances did not run.
- 02-sbom-inventory **OK_WITH_GAPS** — syft found 0 components; vendored cJSON has no manifest. Second source (build index vendored members) not yet wired.
- 02-sca-vulnerability-match **BLOCKED** — Blocked on V16/V18 offline vulnerability DB mirror. No CVE matching was performed.
- 02-dependency-lifecycle **BLOCKED** — EOL reference table unowned. Lifecycle of cJSON 1.7.18 reported unknown.
- 02-binary-hardening **BLOCKED** — M02 unresolved; no ELF hardening check ran on the built binary.
- 06-cve-reachability **OK_WITH_GAPS** — No SCA matches to triage (02-sca **BLOCKED**); inventory from build index only.
- L6B threat-model reconciliation **NOT_BUILT** — Designed in design-v3, no lane.
- L10 protocol/parser analysis **NOT_BUILT** — Designed in design-v3, no lane.
- L12 supply-chain / provenance **NOT_BUILT** — Tier B scripts exist, not wired.
- L13 privacy / data protection **NOT_BUILT** — Designed in design-v3, no lane.

5 Scoring method

5.1 Finding priority

Lane 12 computes the CVSS 4.0 score S_f from the vector. Priority adjusts it by how strong the evidence is, whether it survived verification, whether the code is reachable, and exploitation signals:

$$P_f = \min(10, S_f \cdot e_f \cdot v_f \cdot r_f \cdot t_f), \quad t_f = 1 + \beta_{\text{KEV}} \mathbf{1}[\text{KEV}] + \beta_{\text{EPSS}} \text{EPSS}_f$$

EVIDENCE e		VERIFICATION v		REACHABILITY r	
DIRECT_EVIDENCE	1.0	VERIFIED	1.0	reachable-default	1.0
STRONG_INFERENCE	0.8	UNRESOLVED	0.7	reachable-flag	0.85
WEAK_INFERENCE	0.5	REFUTED	0.0	reachable-build-config	0.75
				unknown	0.7
				unreachable	0.3

$\beta_{\text{KEV}} = 0.5$, $\beta_{\text{EPSS}} = 0.5$. Severity bands follow CVSS 4.0 qualitative ratings applied to P_f .

5.2 Process assurance

$$c_i = \begin{cases} 1 & \text{OK} \\ \text{coverage}_i & \text{OK_WITH_GAPS} \\ 0 & \text{BLOCKED, FAILED, NOT_BUILT} \\ \emptyset & \text{SKIPPED_NA (with probe receipt)} \end{cases} \quad A_k = \frac{1}{|K_k|} \sum_{i \in K_k} c_i \cdot \kappa_k$$

κ_k is the native tier cap ($A = 1.0$, $B = 0.85$, $C = 0.6$), applied only to the native family.

5.3 Overall rating

$$\text{rating} = \text{band} \left(\max_{f \notin \text{refuted}} P_f \right), \quad \text{rating} \in \{\text{None, Low}\} \wedge A < 0.85 \Rightarrow \text{Indeterminate}$$

A low score is only reported as low when enough of the process ran to support it.

A Evidence register

ID	PRODUCER	ARTIFACT	SHA256
E-001	00-intake	data/jobs/00-intake/manifest.json	3f9a1c0e
E-002	02-repository-partition-discovery	attempt-1/repository-partition-map.json	a41be209
E-003	02-build-index	data/jobs/02-build-index/build-index.json#vendored[0]	0c7d55e1
E-004	native-build	compile_commands.json (6 project TUs + cJSON.c)	e8812fd0
E-010	gitleaks	02-secrets-inventory/gitleaks/outputs/findings.json (0 hits) + redaction-receipt.json	5b2e0a77

ID	PRODUCER	ARTIFACT	SHA256
E-011	hadolint, checkov, trivy-config	02-iac-config-scan/tool-results.json	91d0c3e6
E-012	syft-directory	02-sbom-inventory/syft-directory/outputs/sbom.cdx.json (0 components)	77ac21b9
E-013	scancode-toolkit	02-license-scan/outputs/scancode.json#vendor/cJSON-1.7.18 (MIT)	c2f9084d
E-014	semgrep	02-source-sast/semgrep/outputs/results.sarif (greet.cpp:18, logger.cpp:16, runner.cpp:18, jsonreport.cpp:19)	4ae6f19c
E-015	ossf-scorecard	ossf-scorecard/scorecard.json (aggregate 4.1)	d03b8e2c
E-020	clang-tidy, cppcheck	native/clang-tidy.sarif, cppcheck.xml	12fe7a09
E-021	ir-facts / component IR slice	native/ir-slices/*.json (memcpy@store.h:30 N=16; system@runner.cpp:18)	6d8b03e5
E-022	csa-ctu	native/csa/*.plist (greet.cpp:18, jsonreport.cpp:17)	b90c4e17
E-023	codeql	codeql/security-extended.sarif + mythos-cpp.sarif	f15a2d8c
E-024	deep-confirmation	deep-confirmation.json cluster C-007	280e6b4f
E-030	03-threat-model-dfd-stride	outputs/03/dfd.json, stride.json	8c4f1a93
E-040	09-independent-verification	outputs/09/verification.json (ASan logs attached)	ee07b6d2

B Provenance

RUN	20260927T141502Z-7a3e91 (SAT 20260927T141440Z)
PIPELINE	report-template (from origin/main b3b87de2)
LEDGER HEAD	sha256:6e1d...b38c
NATIVE TIER	A — clang compiled 6/6 project TUs plus vendored cJSON; IR, CSA/CTU and SVF substrate available (ADR-0001).
tool-gitleaks	sha256:1c4e...9a02
tool-semgrep	sha256:7b10...e33f
tool-syft	sha256:a9d2...4410
tool-checkov	sha256:55e0...b7c1
tool-trivy	sha256:03fd...8e29
tool-hadolint	sha256:c871...1d5a
scancode-toolkit	sha256:e2a4...70bb
audit-native	sha256:9f31...c6d8
audit-codeql	sha256:4b7a...02e1
claude-sonnet-5 (D01, lanes 07/08/09)	pinned per run by model_version_registry.py
claude-haiku (build plan)	pinned per run